QUEEN Cosmetics

دليل المشروع: المعمارية، المجلدات، الملفات المهمة، الربط بين الواجهة والـAPI، والأمان

MySQL + (الواجهة) Laravel 12 (API) + Next.js 16

تاريخ الدليل: 09-11-2026

مكتوب من الكود الحالي للمشروع (ماشي من الذاكرة)

الفهرس

1. نظرة عامة على المشروع
2. مخطط المعمارية
3. هيكل المجلدات
4. الـBackend (Laravel): كل جزء وشنو كيدير
5. الـFrontend (Next.js): الصفحات والمكونات و `lib` و `store`
6. كيفاش كيتربط الـFrontend بالـBackend
7. قاعدة البيانات والعلاقات
8. الدوال (methods) اللي زدناها فهاد الجلسة
9. الأمان
10. أوامر مهمة
11. ملاحظات وحدود هاد الدليل

> **كيفاش تقرا هاد الدليل:** كل أسماء الملفات والدوال مكتوبة بالإنجليزية كيف هي فالكود (`مثال`)، والشرح بالعربية. العلامات: Backend Frontend قاعدة البيانات.

1) نظرة عامة على المشروع

QUEEN Cosmetics متجر إلكتروني لمستحضرات التجميل فالمغرب، **الدفع عند الاستلام فقط**. المشروع مقسوم لجزئين مستقلين كيتكلمو بينهم بـ HTTP/JSON:

الجزء	التقنية	المنفذ	الدور
`backend-laravel/`	PHP ≥ 8.2، Laravel 12، Sanctum 4، MySQL (`queen_db` فـXAMPP)	`8000`	API فقط (ما فيهاش صفحات). كيحسب الأثمنة والستوك وكيتحقق من الأدوار والمدخلات
`frontend-nextjs/`	Next.js 16 (App Router)، React 19، axios، zustand، GSAP + Lenis	`3000`	الواجهة اللي كيشوفها الزبناء والموظفين. ما كيتكلمش مع قاعدة البيانات أبدا

> **القاعدة الذهبية:** Next.js كيعيط غير لـ Laravel (`/api/...`)، و**Laravel هو اللي كيتحقق من كلشي** (الأثمنة، الستوك، الأدوار، التحقق من المدخلات). أي حماية فالواجهة هي غير للراحة فالعرض.

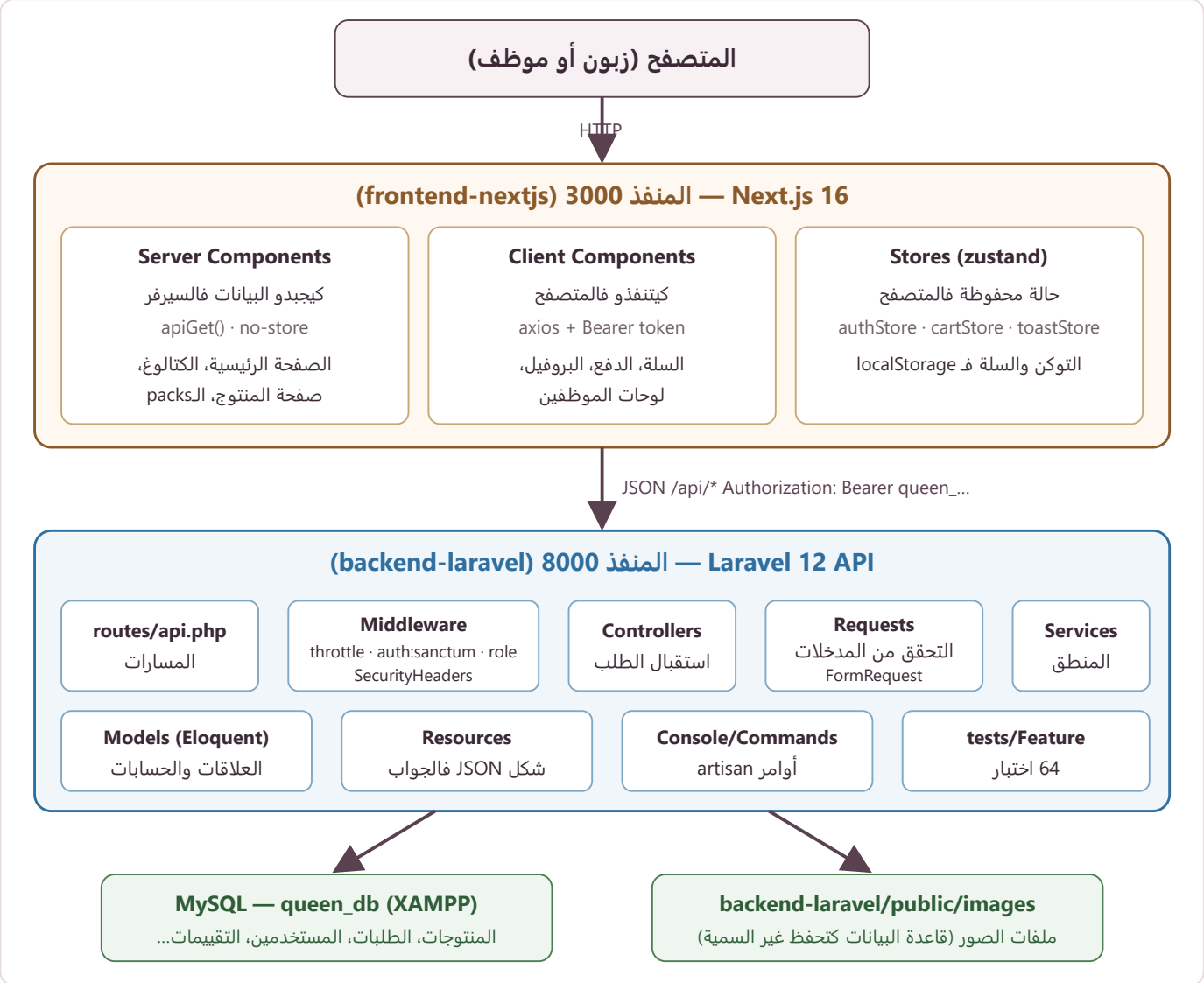
الأدوار الأربعة

الدور (`users.role`)	شنو كيقدر يدير	الصفحة الرئيسية بعد الدخول
`client`	تصفح، سلة، طلب، تقييم، مفضلة، بروفيل، تبليغ (report)	`/`
`responsable_produits`	إضافة/تعديل/حذف المنتوجات والـpacks	`/gestion/produits`
`responsable_commandes`	قبول/رفض/تسليم الطلبات	`/gestion/commandes`
`admin`	لوحة التحكم، المستخدمين، الإعلانات، الشرائط، المظهر، التقييمات، المالية (قراءة فالمنتوجات والطلبات)	`/admin`

مسار حالة الطلب

`En attente` ← (`Acceptee` أو `Refusee`)، و`Acceptee` ← (`Livree` أو `Refusee` = إلغاء). الرفض كيرجّع الستوك، والتسليم كيحوّل الأداء لـ `Paye`.

2) مخطط المعمارية



الشكل 1: الطبقات من المتصفح حتى قاعدة البيانات. السهم الأول HTTP عادي، والثاني JSON مع التوكن.

كيفاش كيدور طلب (Request) وحدة وحدة

1. المتصفح كيطلب صفحة من Next.js.
2. إلا كانت الصفحة **Server Component** (الرئيسية، الكتالوغ...): Next.js كيعيط لـ API من السيرفر ديالو بـ `apiGet()` وكيرجّع HTML جاهز.
3. إلا كانت **Client Component** (السلة، لوحات الموظفين...): المتصفح كيعيط لـ API مباشرة بـ `axios` وكيزيد التوكن `Authorization: Bearer` .
4. Laravel كيدوز الطلب على: `throttle` (حد الطلبات) ← `auth:sanctum` (واش التوكن صحيح) ← `role:...` (واش الدور مسموح) ← Controller.
5. الـController كيستعمل `FormRequest` للتحقق، و`Model` / `Service` للمنطق، من بعد `Resource` كيصاوب الـJSON.

3) هيكل المجلدات

جذر المشروع

المسار	شنو فيه
`backend-laravel/`	الـAPI كاملة (Laravel).
`frontend-nextjs/`	الواجهة (Next.js).
`Database.TEXT` / `Database.txt`	سكريبت SQL ديال الموقع القديم (هيكل `queen_db`). المشروع الحالي كيستعمل الـmigrations.
`README.md`	كيفاش تشغّل المشروع (جزء منو بالدارجة).
`.mcp.json`	إعداد أدوات Claude (Context7 و Playwright). ماشي جزء من الموقع.
`graphify-out/` ، `.desloppify/` ، `.playwright-mcp/`	مخرجات أدوات تحليل ومراجعة الكود. ماشي جزء من الموقع.

داخل `backend-laravel/`

المسار	شنو فيه
`routes/api.php`	كل مسارات الـAPI، مجمّعة حسب الحماية (عام، مسجّل، زبون، موظف، admin).
`app/Http/Controllers/Api/`	15 controller: واحد لكل جزء من الموقع (الدخول، المنتوجات، الطلبات...).
`app/Http/Middleware/`	`EnsureRole` (الأدوار) و `SecurityHeaders` (رؤوس الأمان).
`app/Http/Requests/`	قواعد التحقق من المدخلات (8 ملفات).
`app/Http/Resources/`	كيحدد شكل الـJSON اللي كيرجع للواجهة (8 ملفات).
`app/Models/`	18 موديل كيمثلو الجداول والعلاقات.
`app/Services/`	المنطق الثقيل: `OrderService` ، `CartService` ، `FinanceService` ، `ImageUploader` .
`app/Console/Commands/`	أوامر artisan مخصصة: `products:fetch-images` ، `products:import-images` ، `products:fake-data` .
`app/Providers/`	`AppServiceProvider` : كيعرّف حدود الطلبات (rate limiters).
`bootstrap/app.php`	تسجيل الـmiddleware، وجعل أخطاء الـAPI دايما JSON.
`config/`	الإعدادات: `cors.php` (من يقدر يعيط للـAPI)، `sanctum.php` (صلاحية التوكن)، `database.php` ...
`database/migrations/`	14 migration كتبني وتبدل الجداول.
`database/seeders/`	`DatabaseSeeder` : كيصاوب حسابات التجربة.
`tests/Feature/`	9 ملفات اختبار (64 اختبار).
`public/images/`	ملفات صور المنتوجات والإعلانات والبروفيل.
`storage/logs/`	اللوغات، ومنها قناة `security` (محاولات الدخول المرفوضة...).
`.env`	أسرار الإعداد (كلمة سر DB، مفتاح التطبيق). **ما كيتتبعش فـgit**.
`vendor/`	مكتبات composer. ما كتتلمسش.

داخل `frontend-nextjs/`

المسار	شنو فيه
`src/app/`	الصفحات (App Router): كل مجلد فيه `page.jsx` = رابط (URL). `layout.jsx` = الهيكل المشترك (navbar + footer).
`src/components/layout/`	مكونات كبيرة (بطاقة منتوج، navbar، جداول الموظفين...). المجلدات الفرعية `navbar/`، `products-table/`، `orders-table/`، `packs-manager/` فيها أجزاء من مكون كبير.
`src/components/ui/`	مكونات صغيرة قابلة للاستعمال فكل مكان: `Button`، `Modal`، `Field`، `Stars`، `Pager` ...
`src/lib/`	دوال مساعدة بلا واجهة: الاتصال بالـAPI، التنسيق، الفلترة، الثيم، الأمان.
`src/store/`	حالة التطبيق (zustand): التوكن، السلة، الإشعارات.
`public/`	ملفات ثابتة (`images/logo.webp`، `images/login.png` للصورة ديال صفحة الدخول).
`tests/`	8 ملفات اختبار بـ `node --test` (41 اختبار) للدوال فـ `lib`.
`next.config.js`	إعداد الصور (من فين مسموح) ورؤوس الأمان.
`.env.local`	`NEXT_PUBLIC_API_URL` = عنوان الـAPI. **ما كيتتبعش فـgit**.
`.next/`	مخرجات البناء. ما كتتلمسش.

4) الـBackend (Laravel): كل جزء وشنو كيدير Backend

4.1 المسارات `routes/api.php`

المسارات كلها كتبدا بـ `/api` وكتتقسم لخمس مجموعات حسب الحماية:

المجموعة	الحماية	أمثلة
عامة	`throttle:api` (120 طلب فالدقيقة)	`GET /products`، `/packs`، `/categories`، `/theme`، `/top-bars`، `/advertisements`، `POST /auth/login`، `/cart/check`
مسجّل الدخول	`auth:sanctum`	`GET /auth/me`، `POST /auth/logout`
زبون	`role:client`	`/profile`، `/reports`، `/notifications`، `POST /orders`، `/products/{id}/reviews`، `/favorites`
موظف	`role:responsable_produits` أو `responsable_commandes` (+ admin للقراءة)	`/manage/products`، `/manage/packs`، `/manage/orders`
admin	`role:admin` + بريفكس `/admin`	`/admin/dashboard`، `/admin/users`، `/admin/theme`، `/admin/reviews` ...

4.2 الـControllers (`app/Http/Controllers/Api/`)

الملف	الدور	الدوال المهمة
`AuthController`	الدخول والتسجيل	`login`، `register`، `me`، `logout`، `tokenResponse` (كيصاوب التوكن)
`ProductController`	المنتوجات للزبناء وللموظفين	عام: `index`، `show`، `suggestions`، `categories`. موظف: `manageIndex`، `store`، `update`، `destroy` (corbeille)، `restore`، `forceDestroy`. داخلي: `fields`، `syncExtras` (المعرض والـvariants)

`PackController`	العروض المجمّعة (packs)	`index` ، `show` ، `manageIndex` ، `store` ، `update` ، `destroy` ، `productLinks`
`CartController`	مراجعة السلة	`check` (كيعاود يحسب من DB)
`OrderController`	طلبات الزبون	`store` (إنشاء طلب)، `notifications` ، `notificationsCount`
`OrderManagementController`	الطلبات عند الموظف	`index` ، `updateStatus`
`FavoriteController`	المفضلة	`index` ، `products` ، `toggle`
`ReviewController`	التقييمات (الزبون يكتب، admin كيوافق)	`index` ، `mine` ، `store` ، `destroyMine` ، `adminIndex` ، `adminUpdate` ، `adminDestroy`
`ProfileController`	حساب الزبون	`show` ، `update` ، `updateImage` ، `destroyImage` ، `destroy` (حذف الحساب بكلمة السر)
`ReportController`	تبليغات الزبناء	`store` ، `adminIndex`
`AdvertisementController`	إعلانات البانر	`index` ، `store` ، `update` ، `destroy`
`TopBarController`	الشرائط فوق الموقع وروابط التواصل	`index` ، `serviceLinks` ، `headerUpdate` ، `uspStore/Update/Destroy` ، `promoStore/Update/Destroy`
`ThemeController`	مظهر الموقع (ألوان، خطوط...)	`show` ، `update` ، `reset` ، `logoStore` ، `logoDestroy`
`UserController`	إدارة المستخدمين (admin)	`index` ، `store` ، `update` ، `destroy` ، `abortIfAdmin`
`AdminController`	لوحة التحكم والمالية	`dashboard` ، `finances`

4.3 الـServices (المنطق الثقيل)

الملف	الدوال	شنو كيدير
`OrderService`	`create` ، `changeStatus`	**create:** كيصاوب الطلب + تفاصيلو + الأداء فـ**transaction واحدة**. الأثمنة كتجي دايما من DB (ماشي من المتصفح). كيقفل الصفوف (`lockForUpdate`) باش جوج زبناء فنفس الوقت ما يشريوش آخر قطعة. الستوك كيتنقص بشرط ما ينزلش تحت 0. كيعالج الـpacks (الثمن الواحد كيتوزع على المنتوجات). **changeStatus:** كيراقب الانتقالات المسموحة، الرفض كيرجّع الستوك، التسليم كيخلّص الأداء.
`CartService`	`lines`	السلة كتعيش فالمتصفح؛ هنا كنعاودو نحسبوها من DB: أثمنة (مع الـpromo) وستوك محيّن وكنحيّدو السطور الغالطة. حد أقصى 30 سطر و20 قطعة للسطر.
`FinanceService`	`summary` ، `perDay` ، `payments`	أرقام المالية للـadmin: الملخص، المبيعات حسب اليوم، لائحة الأداءات.
`ImageUploader`	`store`	كيحفظ الصورة فـ `public/images` بسمية عشوائية، والامتداد كيتحدد من نوع الملف الحقيقي (MIME).

4.4 الـModels والعلاقات المهمة (`app/Models/`)

الموديل	جدول	الأشياء المهمة

`Product`	`produits`	علاقات: `variants` ، `images` ، `reviews` ، `favorites` ، `advertisements` . **SoftDeletes** (عمود `supprime_le` = corbeille). `scopeWithPromo` (يحسب أعلى تخفيض ومعدل النجوم)، `scopeForShop` (المتوفر أولا ثم الأحدث)، `promoPercent` ، `finalPrice` ، `basePrice` ، `syncVariantStock` (الستوك = مجموع variants)، `sansImage` (منتوجات بلا صورة)، `imageUrl`
`ProductVariant`	`variantes_produits`	لون/حجم/وزن/عدد، وستوك خاص بكل واحد. `sizeLabel` كيركّب النص اللي كيشوف الزبون (`50 ml · SPF50`).
`Pack`	`packs`	`products` (n-n عبر `pack_produit`)، `availableCount` (شحال من pack كيتباع بالستوك الحالي)، `separateValue` (قيمة المنتوجات بلا pack)، `splitForOrder` (توزيع ثمن الـpack على المنتوجات)
`Order` / `OrderItem` / `Payment`	`commandes` / `details_commandes` / `paiements`	الحالات (`STATUTS`) والانتقالات المسموحة (`TRANSITIONS`) والحدود (`MAX_EN_ATTENTE_PAR_CLIENT` = 5، `MAX_PAR_HEURE` = 10). `canMoveTo` .
`User`	`utilisateurs`	الأدوار (`ROLES`)، كلمة السر فعمود `mot_de_passe` (كتتشفّر تلقائيا)، `homePath` (الصفحة الرئيسية حسب الدور)
`Review` ، `Favorite` ، `Address` ، `Report`	`avis_produits` ، `favoris` ، `adresses_livraison` ، `reclamations`	تقييمات (كتبان غير ملي admin يوافق)، مفضلة، عناوين، تبليغات
`Advertisement` ، `HeaderSetting` ، `PromoAnnouncement` ، `Usp` ، `ServiceLink`	`publicites` ، `parametres_header` ، `annonces_promo` ، `usps` ، `liens_service`	محتوى الموقع اللي كيتبدل من لوحة admin (بانر، شرائط، روابط)
`ThemeSetting`	`parametres_theme`	مظهر الموقع محفوظ كـJSON: `current` و `payload`

4.5 الـRequests والـResources

- **Requests** (`app/Http/Requests/`): `LoginRequest` ، `RegisterRequest` ، `ProductRequest` ، `PackRequest` ، `AdvertisementRequest` ، `CartCheckRequest` ، `StoreOrderRequest` ، `UserRequest` . كل واحد كيعرّف القواعد (طول، نوع، أقصى حجم صورة...) قبل ما يوصل الطلب للـController.
- **Resources** (`app/Http/Resources/`): `ProductResource` ، `PackResource` ، `OrderResource` ، `OrderItemResource` ، `UserResource` ، `AdvertisementResource` ، `PromoResource` ، `UspResource` . كيحولو الموديل لـJSON بأسماء إنجليزية نقية (`name` ، `price` ، `in_stock` ...) بينما DB بالفرنسية (`nom` ، `prix` ...).

4.6 أوامر artisan المخصصة (`app/Console/Commands/`)

الأمر	شنو كيدير
`products:fetch-images`	كيحمّل صور منتوجات (بلا صورة) من Open Beauty Facts لمجلد، مع `report.csv` . الخيار `--souple` كيقبل صورة تقريبية.
`products:import-images <dossier>`	كيربط الصور اللي فالمجلد بالمنتوجات (حسب الـid أو السمية). `--list` كيعرض المنتوجات بلا صورة.
`products:fake-data`	بيانات تجربة: variants (ألوان/أحجام) منطقية، ستوك متنوع، وتقييمات 2–5 نجوم. `--undo` كيرجّع كلشي للأصل.

5) الـFrontend (Next.js): الصفحات والمكونات Frontend

5.1 الصفحات (src/app/)

الرابط	الملف	شنو كيبان / كيعيط لـ
/	page.jsx	البانر + الكتالوغ بصفوف حسب الفئة + "Nos packs" + شريط التوجيه. كيجيب (Server) advertisements ، products ، categories ، packs
/products	products/page.jsx	الكتالوغ الكامل والبحث (?q=) والفلترة (?cat=&sub=)
/products/[id]	products/[id]/page.jsx	صفحة المنتوج: ألوان وأحجام، "Vous aimerez aussi"، التقييمات (Reviews)، المفضلة (useFavorite)
/packs ، /packs/[id]	packs/...	الـpacks وصفحة كل pack (إضافة للسلة)
/cart	cart/page.jsx	السلة من cartStore + اقتراحات (/products/suggestions)
/checkout	checkout/page.jsx	الدفع: POST /cart/check ثم POST /orders
/login ، /register	login/ ، register/	الدخول والتسجيل (AuthShell ، AuthField)
/profile (+ favorites ، orders ، report)	profile/...	حساب الزبون: المعلومات، الصورة، حذف الحساب، المفضلة، الطلبات (عبر /notifications)، التبليغ
/gestion/produits ، /gestion/packs ، /gestion/commandes	gestion/...	لوحات الموظفين (محمية بـ RequireRole)
/admin وأبناؤه	admin/...	produits ، commandes ، packs ، finances ، utilisateurs ، publicites ، barres ، apparence ، avis ، reports
—	layout.jsx ، error.jsx ، not-found.jsx	الهيكل العام، صفحة الخطأ، صفحة 404

5.2 الهيكل المشترك (layout.jsx)

كل صفحة كتتعرض داخل: ThemeStyle (الألوان والخطوط من API) ← Chrome (كيخبّي الشرائط والـnavbar فصفحات الدخول) ← TopBarsLoader + Navbar ← SmoothScroll + Toaster ← المحتوى ← Footer .

5.3 المكونات المهمة (src/components/)

المكون	شنو كيدير
AdsCarousel	بانر الإعلانات: تنقل أوتوماتيكي، نقط، بادج التخفيض.
ProductsBrowser	قلب الصفحة الرئيسية والكتالوغ: شريط الفئات، الصفوف، البحث، ترتيب الـpacks. كيستعمل lib/catalog.js .
ProductCard / PackCard / PacksSection	بطاقة منتوج (ماركة، اسم، نجوم، ثمن)، بطاقة pack (ثمن + توفير)، قسم "Nos packs".
GuidanceStrip	شريط "Besoin d'un coup de pouce ?": 7 اختصارات للفئات.
Navbar + navbar/AccountMenu ، NavSearch	القائمة العليا، البحث، قائمة الحساب. ClientNavbar للزبون.

`TopBars` / `TopBarsLoader` / `SiteLogo` / `Footer`	الشرائط العليا (من API)، الذيل، اللوغو.
`RequireRole`	كيحمي صفحة الموظفين: إلا ما كانش الدور مناسب كيحول المستخدم. **للراحة فقط** (الحماية الحقيقية فـ Laravel).
`ProductsTable` + `products-table/*`	جدول المنتوجات عند الموظف: `ProductFilters` (الفلاتر)، `ProductRow` ، `ProductStats` ، `ProductActionDialog` (تأكيد Oui/Non).
`OrdersTable` + `orders-table/*`	جدول الطلبات وتغيير الحالة (`StatusChips` ، `OrderRow`).
`PacksManager` + `packs-manager/*`	إنشاء وتعديل الـpacks (`PackProductsPicker` = البحث واختيار المنتوجات، `PackLookFields` = الألوان والزر).
`AuthShell` (`AuthField` +)	هيكل صفحتي الدخول والتسجيل: الصورة + الفورم، وحقل كلمة السر بزر العين.
`Chrome` ، `ScrollTop` ، `SmoothScroll`	إخفاء الـnavbar فصفحات الدخول؛ فتح الصفحة من فوق؛ تمرير ناعم (Lenis).
`ui/*`	`Button` ، `Modal` ، `DialogActions` ، `Field` ، `FormError` ، `Stars` ، `Pager` ، `QuantityInput` ، `StatusPill` ، `Thumb` ، `Avatar` ، `TrustBadges` ، `VariantTag` .

5.4 الدوال المساعدة (`src/lib/`) والحالة (`src/store/`)

الملف	الدوال	شنو كيدير
`api.js`	`api` ، `errorMessage` ، `fieldErrors`	نسخة axios جاهزة (التوكن كيتزاد تلقائيا، وإلا رجع 401 كيتمسح)، وتحويل أخطاء الـAPI لنص أو لأخطاء الحقول.
`serverApi.js`	`API_URL` ، `apiGet`	قراءة الـAPI من Server Components (`cache: no-store` باش الأثمنة والستوك يكونو دايما محيّنين).
`auth.js`	`login` ، `register` ، `logout` ، `refreshMe` ، `homeFor` ، `isStaffPath` ، `nextPath`	الدخول والخروج وحفظ الجلسة، وصفحة الاستقبال حسب الدور.
`catalog.js`	`groupBy` ، `searchCatalog` ، `layoutCatalog`	تجميع المنتوجات فصفوف حسب الفئة، والبحث (اسم، ماركة، فئة، pack).
`productFilters.js`	`filterProducts` ، `productsInView` ، `uniqSorted`	منطق فلاتر جدول المنتوجات (فئة، فئة فرعية، توفر، نجوم، تخفيض، ثمن).
`productForm.js`	`productToForm` ، `variantsToRows` ، `rowsToVariants` ، `variantsTotal`	تحويل بين الفورم ديال المنتوج وبياناتو (variants).
`format.js`	`money` ، `dateTime` ، `dayDate` ، `norm` ، `statusInfo`	تنسيق الثمن (`1 234,50 DH`) والتواريخ، وتنظيف النص للبحث (بلا accents).
`quantity.js`	`clampQty` ، `typedQty`	تحديد الكمية بين 1 والحد الأقصى.
`safePath.js`	`safeInternalPath`	كيسمح بالتحويل (`?next=`) غير لروابط داخلية: **ما كاين open redirect**.
`theme.js` / `themeServer.js`	`themeVars` ، `themeCss` ، `contrastRatio` ، `getTheme`	تحويل إعدادات المظهر لـCSS، وحساب التباين، وجلب الثيم من API.

`useHydrated.js` ، `useReveal.js` ، `useSubmit.js`	`useHydrated` ، `useLayoutPathname` ، `useScrollReveal` ، `useEntrance` ، `useSubmit`	hooks: واش الصفحة تحمّلات فالمتصفح، الرابط الحالي، حركات الظهور، وإرسال الفورمات.
`adultDate.js` ، `barIcons.jsx`	`latestAdultBirthDate` ، `BarIcon`	أقصى تاريخ ازدياد لشخص بالغ، وأيقونات الشرائط.
`store/authStore.js`	`useAuthStore`	التوكن والمستخدم، محفوظين فـ `localStorage` تحت `queen-auth` .
`store/cartStore.js`	`useCartStore` ، `useCartCount` ، `lineKey`	السلة (حد أقصى `MAX_LIGNES` سطر و `MAX_QTE` قطعة).
`store/toastStore.js`	`toast`	رسائل النجاح والخطأ الصغيرة.

6) كيفاش كيتربط الـFrontend بالـBackend Front ↔ Back

6.1 قناتان للاتصال

القناة	الملف	تستعمل فين
من السيرفر (Next.js)	`lib/serverApi.js` ← `apiGet(path)` بـ `fetch`	الصفحات العامة (الرئيسية، الكتالوغ، صفحة المنتوج، الـpacks، الثيم). بلا توكن، وبلا cache.
من المتصفح	`lib/api.js` ← نسخة `axios`	كل شي محتاج المستخدم: السلة، الدفع، البروفيل، لوحات الموظفين. كيزيد `Authorization: Bearer` .

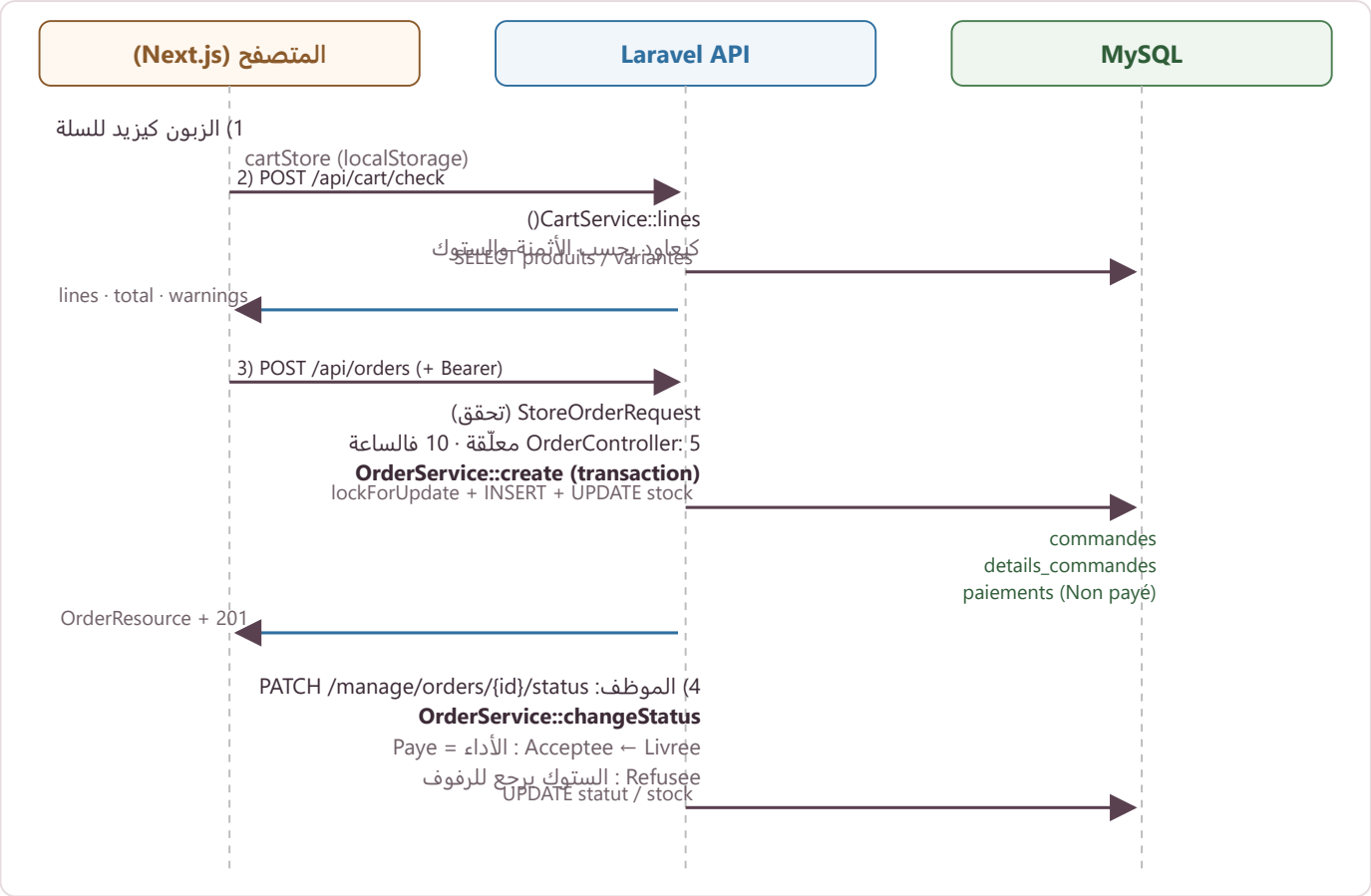
عنوان الـAPI واحد للقناتين: `NEXT_PUBLIC_API_URL` فـ `.env.local` (الافتراضي `http://localhost:8000`).

6.2 مسار الدخول (التوكن)

1. الفورم كيعيط `login()` فـ `lib/auth.js` ← `POST /api/auth/login` .
2. Laravel (`AuthController::login`) كيتحقق من الحد (5 محاولات) وكلمة السر، وكيصاوب **توكن Sanctum** (يبدا بـ `queen_` ، صالح 480 دقيقة = 8 ساعات).
3. الواجهة كتحفظ `{token, user}` فـ `authStore` (`localStorage`).
4. كل طلب من بعد كيدوز على `interceptor` فـ `api.js` اللي كيزيد التوكن.
5. إلا رجع **401** (توكن سالا) ← الواجهة كتمسح الجلسة وكتوجه للدخول.
6. `user.home` (من `User::homePath`) كيحدد فين يمشي المستخدم بعد الدخول.

> **حمايتان وماشي وحدة:** `RequireRole` فالواجهة كتحول المستخدم غير المسموح (راحة فالعرض)، و `EnsureRole` فـ Laravel كيرجع **403** (الحماية الحقيقية، والدور كيتقرا من DB فكل طلب، ماشي من التوكن).

6.3 مسار الطلب (من السلة حتى التسليم)



الشكل 2: الأثمنة والستوك كيتحسبو فـLaravel، والمتصفح كيرسل غير الـid والكمية.

6.4 الصفحات ← النقط ديال الـAPI (ملخص)

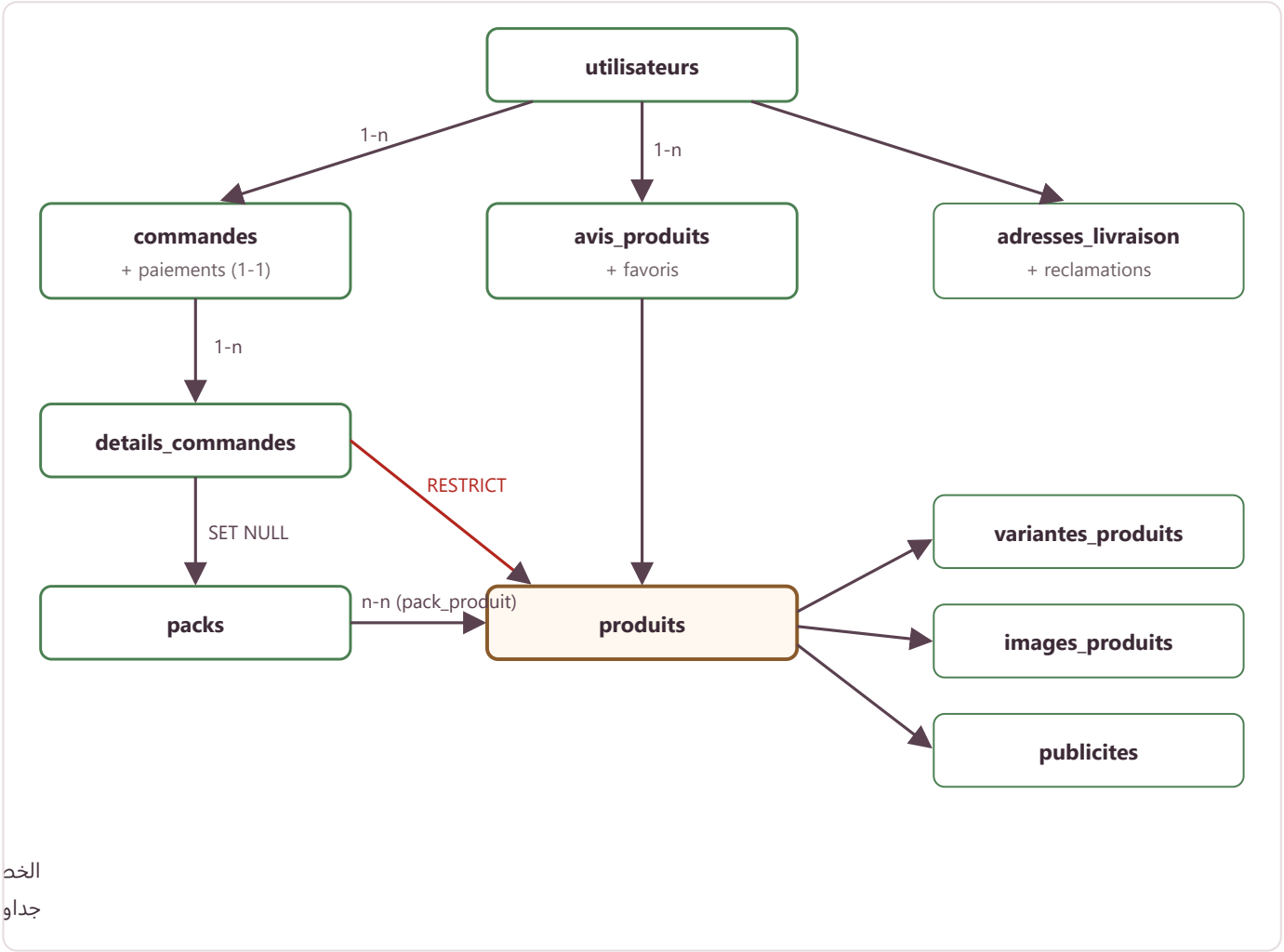
الواجهة	نقط الـAPI
الرئيسية والكتالوغ	`GET /advertisements` ، `/products` ، `/categories` ، `/packs` ، `/top-bars` ، `/theme`
صفحة المنتوج	`GET /products/{id}` ، `/products/{id}/reviews` ، `/products/suggestions?ids=&limit=` ، `POST /products/{id}/favorite` ، `/products/{id}/reviews`
السلة والدفع	`GET /products/suggestions` ، `POST /cart/check` ، `POST /orders`
الدخول	`POST /auth/login` ، `/auth/register` ، `/auth/logout` ، `GET /auth/me`
البروفيل	`GET/PUT/DELETE /profile` ، `POST/DELETE /profile/image` ، `GET /favorites` ، `/favorites/products` ، `/notifications` ، `POST /reports`
موظف المنتوجات	`GET /manage/products` ، `POST /manage/products` ، `POST /manage/products/{id}` (تعديل)، `DELETE /manage/products/{id}` (corbeille)، `POST .../restore` ، `DELETE .../force` ، و `/manage/packs`
موظف الطلبات	`GET /manage/orders` ، `PATCH /manage/orders/{id}/status`
admin	`/admin/dashboard` ، `/finances` ، `/users` ، `/advertisements` ، `/theme` ، `/top-bars` ، `/header` ، `/promos` ، `/usps` ، `/service-links` ، `/reviews` ، `/reports`

CORS 6.5

`config/cors.php` : كيسمح غير للأصل (origin) اللي فـ `FRONTEND_URL` (الافتراضي `http://localhost:3000`)، وغير لـ `api/*` ، وغير للـheaders `Content-Type، Accept، Authorization، X-Requested-With` . `supports_credentials` = `false` لأن التوثيق بالتوكن (Bearer) ماشي بالكوكيز.

7) قاعدة البيانات والعلاقات DB

قاعدة البيانات `queen_db` (MySQL فـXAMPP). الأسماء بالفرنسية. الرسم يوري العلاقات الأساسية:



الخط
جداو

الشكل 3: العلاقات الأساسية. أرقام الصفوف الحالية: produits 109 (منها المحذوفة فـ corbeille)، commandes 17، avis_produits 302، variantes_produits 282.

قواعد الحذف (المفاتيح الأجنبية)

العلاقة	عند الحذف	المعنى
`commandes.client_id` ← utilisateurs	`RESTRICT`	ما تمسحش مستخدم عندو طلبات (الحساب كيتجهّل: الاسم كيولي "Compte supprimé")
`details_commandes.produit_id` ← produits	`RESTRICT`	ما يتمسحش نهائيا منتوج دخل فطلب
`details_commandes.commande_id` ، `paiements.commande_id`	`RESTRICT`	الطلب والأداء ما كيتمسحوش بالخطأ
`details_commandes.variante_id` ، `.pack_id`	`SET NULL`	إلا تمسحت variante أو pack، التاريخ كيبقى

`variantes_produits` ، `images_produits` ، `avis_produits` ، `favoris` ، `pack_produit` ← produits	`CASCADE`	كيتمسحو مع المنتوج
`reclamations.utilisateur_id`	`SET NULL`	التبليغ كيبقى بلا صاحب

الـmigrations الأخيرة

`add_soft_delete_to_produits` (عمود `supprime_le` للـcorbeille)، `add_prix_to_variantes_produits` (ثمن خاص بالـvariante)، `create_parametres_theme_table` (المظهر)، `add_pack_customization_and_orders` ، `create_reclamations_table` ، `create_liens_service_table` .

8) الدوال (methods) اللي زدناها فهاد الجلسة

> **مهم:** المشروع تبدل بزاف فنفس الوقت (مثلا الثيم، وتقسيم بعض المكونات لمجلدات فرعية). هادي هي الأسماء الحالية؛ بعض الدوال تنقلات لملف آخر بعد التنظيف.

Backend

الاسم	الملف
`ProductController::destroy`	`oller.php`
`ProductController::restore`	نفسو
`ProductController::forceDestroy`	نفسو
`ProductController::manageIndex` (محدّثة)	نفسو
`ProductController::suggestions` (محدّثة)	نفسو

`Product::sansImage`	`oduct.php`
`Pack::products()->withTrashed()` و `availableCount` (محدّثة)	`Pack.php`
`OrderItem::product` / `Review::product` (`withTrashed`)	الموديلات
`OrderService::changeStatus` (محدّثة)	`rvice.php`
`PackResource` (محدّث)	`ource.php`
`FetchProductImages::handle / find`	`mages.php`
`ImportProductImages::handle`	`mages.php`
`SeedTestData::generate / undo / recipe / byName / bySubCategory / stock / pick / shades / sizes / combos`	`tData.php`

Frontend

الاسم	الملف	الوظيفة
`GuidanceStrip`	`GuidanceStrip.jsx`	شريط الاختصارات بـ7 بطاقات (الـ6 + packs فئات موجودة فعلا).

`PacksSection` و `PackCard` (معاد تصميمها)	مكونات الـpacks	قسم واحد "Nos packs" بدل شريطين، والبطاقة فيها الثمن والتوفير والزر.
`ProductCard` (معاد تصميمها)	`ProductCard.jsx`	ماركة، اسم، نجوم، ثمن (بلا وصف).
`searchCatalog` و `norm`	`lib/catalog.js` ، `lib/format.js`	بحث بكل كلمة فالاسم والماركة والفئتين والـpacks، بلا اعتبار الحروف الكبيرة والـaccents.
`filterProducts` / `ProductFilters`	`products-table/` ، `lib/productFilters.js`	فلاتر جدول المنتوجات: الفئة ثم الفئة الفرعية، التوفر، النجوم، الـpromo، الثمن، وcorbeille.
`ProductActionDialog`	`products-table/`	نافذة التأكيد **Oui / Non** قبل الحذف أو الاسترجاع أو الحذف النهائي.
`PackProductsPicker`	`packs-manager/`	اختيار منتوجات الـpack: خانة بحث كتصفّي لائحة منسدلة + زر Ajouter.
`AuthShell` و `AuthField`	`AuthShell.jsx`	تصميم الدخول والتسجيل (صورة + فورم)، وحقل كلمة السر بزر العين.
`useLayoutPathname` / `Chrome`	`Chrome.jsx` ، `lib/useHydrated.js`	إخفاء الشرائط والـnavbar فصفحات الدخول بلا ما يتكسر الـbuild.
`ScrollTop`	`ScrollTop.jsx`	صفحة المنتوج والـpack كتفتح من فوق.
`ProductsBrowser` (محدّث)	`ProductsBrowser.jsx`	تمرير أوتوماتيكي لنتائج البحث، قسم الـpacks مرة وحدة، وشريط التوجيه قبل آخر صف.
قسم "Vous aimerez aussi"	`products/[id]/page.jsx`	6 منتوجات من نفس الفئة الفرعية قبل التقييمات، و"Voir plus >" إلا كانو أكثر.
class `.soldout`	`ProductHero.jsx` + `globals.css`	اللون أو الحجم بلا ستوك كيبان باهت وبخط مائل (كان تضارب مع class `.empty`).
"Règles typographiques"	آخر `globals.css`	سلم خطوط مستوحى من Sephora: 12/14/16/20/24 وأوزان 400 و700.

9) الأمان Backend Frontend

كل نقطة هنا مبنية على الكود الحالي، ومعاها فين كتلقاها. 13 اختبار فـ `SecurityTest` كيغطيو جزء كبير منها.

9.1 التوثيق وكلمات السر

الحماية	التفاصيل
توكن Sanctum	صالح 480 دقيقة (`SANCTUM_EXPIRATION`)، يبدا بـ `queen_` . كل خروج كيمسح التوكن (`logout`).
تشفير كلمات السر	الموديل كيشفّر بـ `hashed` (bcrypt)، وكيعاود التشفير تلقائيا إلا تقادم الـhash (`Hash::needsRehash`). القواعد: 8 أحرف على الأقل، حرف كبير، أقصى 72.
ما كاينش تخمين الإيميلات	نفس الرسالة ("Email ou mot de passe incorrect.") ونفس وقت الحساب حتى إلا كان الإيميل ما كاينش (`Hash::make('queen-timing-dummy')`).
قفل الدخول	5 محاولات فاشلة لنفس الحساب ← قفل 5 دقائق، **حتى من IP آخر**؛ و30 محاولة لكل IP فـ15 دقيقة. كيتسجل فقناة `security` .

حذف الحساب	كيطلب كلمة السر (توكن مسروق ما كيكفيش)، بنفس قفل الدخول، وممنوع إلا كانت طلبية جارية. الحساب اللي عندو طلبات كيتجهّل ماشي كيتمسح.

9.2 الأدوار والصلاحيات

- `EnsureRole` : الدور كيتقرا **من DB فكل طلب** (التوكن ما فيهش الدور)، فلو تبدّل دور مستخدم كيتطبق فورا. المحاولة المرفوضة كتتسجل (`acces_refuse`).
- الزبون ما يقدرش يرقّي راسو؛ admin ما يقدرش يصاوب admin آخر؛ حسابات admin ما كيتعدلوش ولا كيتمسحوش؛ مستخدم عندو طلبات ما كيتمسحش (`UserController::abortIfAdmin` + الاختبارات).
- الاختبارات: `RoleAccessTest` كيتحقق أن كل دور كيوصل غير لمنطقتو.

9.3 حدود الطلبات (Rate limiting)

المسار	الحد
الـAPI العامة	120 طلب/دقيقة (حسب المستخدم أو الـIP)
التسجيل `/auth/register`	10/ساعة لكل IP
رفع الملفات (`uploads`)	30/دقيقة
التبليغات `/reports`	5/دقيقة
الطلبات `POST /orders`	10 فالساعة لكل زبون + 5 طلبات معلّقة كحد أقصى

9.4 التحقق من المدخلات والملفات

- كل المدخلات كتدوز على `FormRequest` (طول، نوع، نطاق). مثلا ثمن المنتوج `0 <` ، التخفيض 0–90.
- **الصور:** نوع MIME (`jpeg, png, webp, gif`) وليس الامتداد فقط، أقصى 3 MB، أقصى 6000×6000 px، والاسم الجديد عشوائي (`ImageUploader`). اختبار: ملف PHP متنكر فصورة كيترفض.
- **المظهر (Theme):** الألوان غير بصيغة `#RRGGBB` ، والخطوط والأشكال من لائحة مسموحة (`Rule::in`) ← ما يمكنش حقن CSS (اختبار موجود).
- **روابط الشرائط:** روابط `javascript:` مرفوضة؛ مسموح داخلي أو https (اختبارات `SecurityTest`).
- الواجهة ما كتستعمل `dangerouslySetInnerHTML` فـ `src` (تأكدت بـ grep)، يعني React كيهرب النصوص تلقائيا.

9.5 سلامة البيانات والمال

- **الأثمنة من DB فقط.** المتصفح كيرسل `id` و `quantity` ؛ `OrderService` هو اللي كيحسب (مع الـpromo والـvariants والـpacks).
- **transaction واحدة** + `lockForUpdate` + نقص الستوك بشرط `الكمية <= quantite_stock` : ما يمكنش يتباع أكثر من الموجود ولو جاو جوج زبناء فنفس الثانية.
- **آلة حالات للطلب:** الانتقالات المسموحة غير `En attente → Acceptee/Refusee` و `Acceptee → Livree/Refusee` ، وتغيير مزدوج من جوج موظفين كيتوقف ("vient d'être modifiée").
- مفاتيح أجنبية `RESTRICT` كتحمي تاريخ الطلبات، والحذف الناعم (corbeille) كيخلي المنتوج قابل للاسترجاع.
- `CartService` : حد أقصى 30 سطر و20 قطعة فالسطر.

9.6 رؤوس الأمان والشبكة

الرأس / الإعداد	الأثر
`X-Content-Type-Options: nosniff`	المتصفح ما يخمنش نوع الملف.
`X-Frame-Options: DENY`	الموقع ما يتحطش فـ iframe (حماية من clickjacking). كاين فـ Laravel وفـ `next.config.js` .
`Referrer-Policy: strict-origin-when-cross-origin`	تقليل تسريب الروابط.

`Permissions-Policy`	الكاميرا والميكروفون والموقع معطلين.
حذف `X-Powered-By`	ما كنكشفوش نسخة PHP (اختبار موجود).
`Cache-Control: no-store, private`	أجوبة الـAPI لمستخدم مسجّل ما كتتخزنش.
CORS محدود	غير `FRONTEND_URL` ، وغير `api/*` .
أخطاء JSON دايما	`bootstrap/app.php` : ما كاينش HTML ولا stack trace فجواب الـAPI.
`safeInternalPath` (الواجهة)	كيمنع **open redirect**: `?next=//evil.com` أو `javascript:` كيتحيدو.
الأسرار	`backend-laravel/.env` و `frontend-nextjs/.env.local` **كاينين فـ gitignore**. كلمة سر الـseed كتجي من `SEED_PASSWORD` (ما كاينش كلمة سر مكتوبة فالكود، وكاين اختبار كيتأكد من هادشي).

9.7 نقط خاصك تعرفها (ماشي كلها محلولة)

- **التوكن فـ `localStorage` :** أي ثغرة XSS تقدر تسرقو. الواجهة ما فيهاش `dangerouslySetInnerHTML` ، ولكن ما كاينش **Content-Security-Policy** (CSP) فالـheaders. زيادتو كتقلل الخطر.
- **الإنتاج:** خاص `APP_DEBUG=false` ، و**HTTPS**، و `FRONTEND_URL` للدومين الحقيقي. الإعداد الحالي كلو localhost.
- **حدود الطلبات** كتخدم بـ cache `file` (واحد فالسيرفر). فسيرفرات متعددة خاصها cache مشترك (Redis).
- **الملف `.mcp.json` مسجّل فـ git** (ما فيه أسرار، غير إعداد Context7 وPlaywright).
- جدول `tentatives_connexion` موروث من الموقع القديم وما بقاش مستعمل فالكود (القفل الحالي كيستعمل cache).
- **نسخ احتياطية:** ما كاين حتى نظام نسخ احتياطي ديال DB فالمشروع. كتعمل واحد قبل أي عملية كبيرة.

10) أوامر مهمة

```
# تشغيل (Terminal 1) — Laravel 8000 على
cd backend-laravel
php artisan serve

# تشغيل (Terminal 2) — Next.js 3000 على
cd frontend-nextjs
npm run dev

# قاعدة البيانات
php artisan migrate                # تطبيق التغييرات الجديدة
php artisan migrate:status         # شنو تطبق وشنو لا

# الاختبارات
php artisan test                   # 64 اختبار (backend)
npm test                           # 41 اختبار (frontend: node --test)
npm run lint                       # eslint

# الصور والبيانات التجريبية
php artisan products:import-images --list
php artisan products:import-images C:\tsawer
php artisan products:fetch-images --limit=5
php artisan products:fake-data          # يولّد بيانات تجربة
php artisan products:fake-data --undo   # يرجّع كلشي للأصل
```

11) ملاحظات وحدود هاد الدليل

- **شنو تأكدت منو:** قريت الكود الحالي (المسارات، الـControllers، الـServices، الـmiddleware، المفاتيح الأجنبية من DB، رؤوس الأمان، القواعد) وعدّيت الاختبارات. أرقام الصفوف أخدتها من DB فنفس اللحظة.
- **شنو ما شغّلتوش:** ما شغّلت لا `php artisan test` ولا `npm test` فهاد المرحلة؛ عدد الاختبارات (64 و41) هو عدد الدوال فالملفات، ماشي نتيجة تشغيل.
- **ما ذكرتش كلشي:** الدليل كيغطي الملفات المهمة. كل ملف بتفاصيلو (مثلا كل حقول `ProductRequest`) خاصك تقراو فـ الكود مباشرة.
- حسابات التجربة: ما كتبتهاش هنا (كلمة السر كتجي من `SEED_PASSWORD`). README القديم فيه جدول حسابات قد يكون ما بقاش مطابق.
- المشروع كيتبدل، فأي دليل كيقدم لحظة؛ عاود طلبو بعد تغييرات كبيرة.